

SANJAY SHAH

Senior Software Engineer · Java, Spring Boot, Kafka, PostgreSQL, Cloud & Identity

Kathmandu, Nepal · +977 986 327 4892 · messanjayshah@gmail.com · sanjayshah.com.np · linkedin.com/in/mesanjay · github.com/mesanjayshah · credly.com/users/sanjay-shah.861076ff

PROFESSIONAL SUMMARY

Senior Software Engineer with seven years building backend platforms where identity, money and patient data have to be right: a multi-tenant hospital & enterprise ERP platform being extracted from a monolith into domain services (Java 25, Spring Boot, Kafka, PostgreSQL with row-level security, Kubernetes/GitOps); identity and access management for enterprise clients in the US and Europe (OIDC, SAML, SCIM, Okta, Keycloak); and a multi-tenant education SaaS ERP. I work by four values, in this order: **deliver the solution** — working, verified outcomes, not just code; **security** — secure by construction, enforced in the pipeline and at the database; **compliance** — regulation treated as an input, with versioned thresholds and tamper-evident audit trails; and **future-proof** — designs that survive replay, retry and the next extraction.

1 · Deliver the solution

Done means verified end to end through the real path — E2E spec, seeded boot test, live browser.

2 · Security

OIDC front door, tenant isolation that fails closed, encrypted protected fields, SAST/SCA/secrets/IaC gates, signed images.

3 · Compliance

Versioned statutory thresholds, clause-cited annotations, hash-chained financial audit trail, PHI access logging.

4 · Future-proof

Outbox events, idempotent consumers, absolute values on the wire, one DB and migration chain per service, rules that fail the build.

WORK EXPERIENCE

Senior Software Engineer

Nov 2025 – Present

Multi-tenant hospital & enterprise ERP platform (OPD/IPD, lab, radiology, pharmacy, billing, HR & payroll, accounting, inventory, recruitment, CRM)

- **Service extraction standard:** co-authored and enforce the rules a service must meet to count as extracted — own database and Flyway chain, tenant propagated explicitly over HTTP and Kafka record headers and failing closed when absent, consumers idempotent by unique constraint, blocking bounded retry into a dead-letter topic.
- **Tenant isolation:** PostgreSQL row-level security (FORCE RLS, two-role owner/app model), Hibernate tenant and soft-delete filters enabled by aspect, by-id loads that answer 404 on tenant mismatch so existence never leaks.
- **Event-driven integration:** transactional outbox → polling relay → Kafka → idempotent consumers; absolute values on the wire; one authority per fact with projections keyed by the owner's id.
- **Protected data & regulatory engines:** field-level encryption (randomised AES-GCM; deterministic where columns must stay indexable), PHI access logging, hash-chained financial audit trail, annotation-driven compliance traceability with versioned statutory thresholds; integrations with national health reporting (DHIS2), tax-authority e-invoicing and health-insurance claims.
- **Delivery & AppSec:** GitHub Actions → Helm → Argo CD on k3s in AWS, Terraform infrastructure; a shared shift-left security workflow every service inherits — Semgrep with custom rules, Trivy SCA and licence policy, gitleaks, Checkov, Kubescape, CycloneDX SBOM, Cosign-signed images, ZAP pre-release.
- **Quality as a gate:** Playwright end-to-end spec mandatory for every form (incl. tampered POST and cross-tenant id → 404), ArchUnit rules for layering and tenant-scoped loads, JUnit 5 + Mockito, Testcontainers integration tests.
- **AI-assisted engineering:** agent guidance kept in the repository, multi-agent audits, token-discipline skills; agent-written changes verified by the build, the E2E suite and a live browser.

Senior Software Engineer

Aug 2022 – Nov 2025

Identity & access management for enterprise clients (US and Europe)

- Designed and built custom SCIM 2.0 connectors and a bulk migration tool, moving identities from a self-hosted Keycloak to Okta securely and without onboarding delays.
- Delivered identity federation, SSO and platform upgrades on OIDC, SAML and OAuth 2.0 for enterprise clients in sports media and banking, with Okta, Auth0 and Spring Boot across multi-tenant application estates.

- Modernised legacy IAM connector codebases for performance and maintainability; introduced Checkmarx static analysis into the pipeline to enforce secure development.
- Built an internal pre-sales estimation tool (Spring Boot, React) that improved estimate accuracy for enterprise deployments.
- Earned three Okta certifications; mentored engineers on identity standards and secure-by-default integration.

Full Stack Software Developer

Aug 2019 – Feb 2022

Multi-tenant SaaS ERP for education

- Designed and developed HR & Payroll, CRM, CMS and Online Examination modules (React, Spring Boot, PostgreSQL, MySQL).
- Led the re-architecture of the CRM module for usability, maintainability and scale; delivered a 25% performance gain on hot paths.
- Migrated a monolith to a modular Maven/Gradle build and containerised it with Docker on AWS EC2, cutting manual deployment time.
- Contributed to the SaaS foundation redesign, strengthening multi-tenancy and onboarding of new institutions.

SKILLS

Languages	Java 8 → 25 (records, sealed types, virtual threads), SQL, TypeScript, JavaScript
Frameworks	Spring Boot, Spring Security, Hibernate/JPA, React, Thymeleaf, Tailwind CSS, HTMX, Alpine.js
Architecture	Microservices & service extraction, multi-tenancy, event-driven (Kafka, transactional outbox, idempotent consumers), REST, mobile BFF
Data	PostgreSQL (row-level security, two-role model), Flyway, Redis, Testcontainers, MySQL, MongoDB
Cloud & DevOps	AWS (EC2, RDS, ECR, S3, CloudFront, SSM), Docker, Kubernetes (k3s), Helm, Argo CD (GitOps), Terraform/OpenTofu, GitHub Actions, Jenkins, Prometheus/CloudWatch
IAM & Security	OAuth 2.0, OIDC, SAML 2.0, SCIM 2.0, JWT, LDAP, Okta, Auth0, Keycloak, field-level encryption, PII/PHI handling
DevSecOps	Semgrep (custom rules), Trivy, gitleaks, Checkov, Kubescape, Cosign, CycloneDX SBOM, OWASP ZAP, Checkmarx, SonarQube
Testing	Playwright (E2E), JUnit 5, Mockito, Testcontainers, ArchUnit, MockMvc
AI-assisted	Claude Code, MCP servers, multi-agent workflows, agent guidance in the repo, token-discipline skills, agent-written tests verified in a live browser

EDUCATION

- Master of Computer Science — pursuing
- Bachelor of Science in Computer Science — 2015 – 2019

CERTIFICATIONS

- Okta Certified Developer, Customer Identity Cloud — 2024
- Okta Certified Consultant — 2023
- Okta Certified Developer, Workforce Identity Cloud — 2023
- Web Security & Access Management: JWT, OAuth 2.0, OIDC — 2022

Employers and clients are described by domain.